


# รายงานการศึกษาและการออกแบบระบบเครือข่ายความมั่นคงปลอดภัยสูงสำหรับเว็บแอปพลิเคชันบนโครงสร้างพื้นฐาน VPS

จัดทำโดย

67160262 นายปิยวัฒน์ แซ่ซิ่น

67160248 นายกันต์ธีร์ พูนสวัสดิ์พงศ์

67160272 วีรพงศ์ แผนจันทึก

67160068 นายธนกร อิ่มขำ

67160053 นายณัฐรฐนนท์ ศิริกุลญาโณทัย

67160101 นายภาคภูมิ อินทร

67160254 นายจีขื่น ทาม

67160267 นายเรืองเดช มาลา

67160425 ธนัญชัย ธนกุลบดี

รายงานนี้เป็นส่วนหนึ่งของวิชา Computer Networks
หลักสูตรปริญญาวิทยาศาสตรบัณฑิต สาขาวิชาวิทยาการคอมพิวเตอร์
คณะวิทยาการสารสนเทศ มหาวิทยาลัยบูรพา
ปีการศึกษา 2569

# สารบัญ


บทนำ ..... 6

01 — Executive Summary & Objectives ..... 7

เป้าหมายและขอบเขตของระบบ ..... 7

ใครเป็นผู้ใช้งาน และข้อมูลใดมีความสำคัญ ..... 7

เกณฑ์ความสำเร็จของระบบ ..... 7

สรุปความเสี่ยงหลักและแนวทางที่เลือก ..... 8

02 — VPS & Environment Specification ..... 9

ผู้ให้บริการ VPS, CPU, RAM, Storage, Network ..... 9

Ubuntu Version และระยะเวลาการสนับสนุน ..... 9

Domain, DNS, IPv4/IPv6 ..... 9

ข้อจำกัดด้านงบประมาณและ Availability ..... 10

03 — Architecture & Technology Decisions ..... 11

แผนภาพ Architecture และ Data Flow ..... 11

Native หรือ Docker Compose ..... 11

Nginx หรือ Apache ..... 12

PHP-FPM, MariaDB, Reverse Proxy และ Cache ..... 12

เหตุผลที่เลือก พร้อมข้อแลกเปลี่ยนของทางเลือกอื่น ..... 12

04 — Threat Model & Attack Surface ..... 13

ทรัพย์สินที่ต้องปกป้อง (Assets) ..... 13

จุดเข้าถึงระบบและ Trust Boundaries ..... 13

Threat Actors, Entry Points และ Attack Paths ..... 13

ผลกระทบด้าน Confidentiality, Integrity, Availability ..... 13

ความเสี่ยงก่อนและหลังการควบคุม ..... 14

05 — OS & Infrastructure Hardening ..... 15

SSH Key, Least Privilege, sudo ..... 15

Firewall และการปิดบริการที่ไม่จำเป็น ..... 15

Security Updates, AppArmor และ System Logging ..... 15

การจัดการผู้ดูแลระบบและการเข้าถึง VPS ..... 16

06 — Network, DNS, TLS & Edge Security ..... 17
DNS และการตั้งค่า HTTPS/TLS ..... 17
Reverse Proxy และ Trusted Proxy Headers ..... 17
WAF, Rate Limiting และ DDoS Protection ..... 17
จำกัดการเข้าถึง Origin Server ให้เหมาะสม ..... 17
07 — WordPress Application Hardening ..... 19
Core, Plugin และ Theme Updates ..... 19
Administrator MFA และ Least Privilege ..... 19
File Permissions และการปิด Plugin/Theme Editor ..... 19
Login Protection, XML-RPC และ REST API ..... 19
ป้องกันช่องโหว่จาก Plugin และ Theme ..... 20
08 — Database, Secrets & Data Protection ..... 21
Database ไม่เปิดรับ Internet โดยไม่จำเป็น ..... 21
แยก Database User และจำกัดสิทธิ์ ..... 21
ป้องกันการรั่วไหลของ Credentials ..... 21
File Permissions, Encryption และการจัดการข้อมูลสำคัญ ..... 21
09 — Deployment, CI/CD & Supply Chain Security ..... 22
การติดตั้งที่ทำซ้ำได้ ..... 22
การตรึงเวอร์ชันและตรวจสอบ Dependencies ..... 22
การจัดการ Configuration และ Secrets ..... 22
การตรวจสอบก่อน Deploy, Rollback และ Change Control ..... 22
เพิ่ม Container Security หากเลือก Docker ..... 23
10 — Monitoring, Logging & Incident Detection ..... 24
System, Web Server, PHP และ Authentication Logs ..... 24
CPU, RAM, Disk และ Network Monitoring ..... 24
Alert สำหรับพฤติกรรมผิดปกติ ..... 24
การเก็บ Log จากส่วนกลางและการจำกัดสิทธิ์เข้าถึง ..... 24
11 — Backup, Disaster Recovery & Business Continuity ..... 25
Backup Database, WordPress Files และ Configuration ..... 25

Off-site Backup และการป้องกันการลบหรือแก้ไข ..... 25
Recovery Point Objective (RPO) ..... 25
Recovery Time Objective (RTO) ..... 25
สาธิต Restore จาก Backup จริง ..... 26
12 — Security Validation & Adversarial Testing ..... 27
ตรวจสอบพอร์ตและบริการที่เปิดเผย ..... 27
ทดสอบ Authentication, Authorization และ Access Control ..... 27
ตรวจสอบ TLS, HTTP Headers และการตั้งค่า ..... 27
สแกนช่องโหว่และตรวจสอบ Dependencies ..... 28
ทดสอบเฉพาะระบบที่ได้รับอนุญาต โดยไม่ทำให้บริการเสียหาย ..... 29
หมายเหตุเรื่องจำนวนข้อค้นพบและระดับความรุนแรง ..... 29
13 — Performance & Resource Benchmark ..... 30
Response Time: Median, p95, p99 ..... 30
Requests per Second และ Error Rate ..... 30
CPU, RAM, Swap และ Database Query Time ..... 30
ทดสอบ Cache Hit/Miss และ Concurrent Requests ..... 30
เปรียบเทียบผลก่อนและหลังปรับแต่ง ..... 30
14 — Incident Response & Operational Runbook ..... 31
ขั้นตอนรับมือเมื่อ WordPress ถูกเจาะ ..... 31
การจำกัดผลกระทบและเก็บหลักฐาน ..... 31
การหมุนเวียน Credentials และเพิกถอน Session ..... 31
ขั้นตอน Restore และตรวจสอบหลังเหตุการณ์ ..... 32
ผู้รับผิดชอบและช่องทางแจ้งเตือน ..... 32
15 — Results, Cost, Residual Risks & Recommendations ..... 33
ผลลัพธ์เทียบกับเกณฑ์ที่กำหนด ..... 33
ค่าใช้จ่ายรายเดือนและภาระการดูแล ..... 34
ความเสี่ยงที่ยังเหลืออยู่ ..... 34
ข้อจำกัดของการทดสอบ ..... 35
แผนปรับปรุงระยะถัดไป ..... 35

เอกสารและหลักฐานอ้างอิง.....37

# บทนำ

ในปัจจุบันเว็บไซต์เป็นช่องทางสำคัญสำหรับการเผยแพร่ข้อมูลและให้บริการแก่ผู้ใช้งานผ่านเครือข่ายอินเทอร์เน็ตโดยเฉพาะเว็บไซต์ของสถาบันการศึกษาที่ใช้เผยแพร่ข้อมูลหลักสูตรและรายละเอียดที่เกี่ยวข้องกับการศึกษา
อย่างไรก็ตามการให้บริการเว็บไซต์ผ่านอินเทอร์เน็ตทำให้ระบบต้องเผชิญกับความเสี่ยงด้านความมั่นคงปลอดภัยหลายรูปแบบ เช่น
การพยายามเข้าสู่ระบบโดยสุ่มรหัสผ่านการเข้าถึงข้อมูลโดยไม่ได้รับอนุญาต
การตั้งค่าระบบที่ไม่เหมาะสม และการโจมตีที่ส่งผลต่อความพร้อมใช้งานของบริการ

โครงการนี้มีวัตถุประสงค์เพื่อศึกษา ตรวจสอบ และปรับปรุงความมั่นคงปลอดภัยของเว็บเซิร์ฟเวอร์ Alien Buu ซึ่งให้บริการเว็บไซต์แนะนำหลักสูตรวิทยาการสารสนเทศ คณะวิทยาการสารสนเทศ มหาวิทยาลัยบูรพา โดยระบบทำงานบนเครื่องเสมือน Microsoft Azure และใช้ WordPress เป็นระบบจัดการเนื้อหาเว็บไซต์

โครงการนี้ไม่เพียงมุ่งเน้นการแก้ไขปัญหาที่ตรวจพบ
แต่ยังมุ่งศึกษาแนวทางการดูแลระบบเซิร์ฟเวอร์อย่างเป็นระบบ ตั้งแต่การออกแบบโครงสร้าง
การกำหนดสิทธิ์ การตรวจสอบช่องโหว่ การติดตามเหตุการณ์
ไปจนถึงการจัดทำเอกสารผลการดำเนินงาน
เพื่อเป็นแนวทางในการดูแลรักษาความมั่นคงปลอดภัยของเว็บไซต์ในระยะยาว

# 01 — Executive Summary & Objectives

## เป้าหมายและขอบเขตของระบบ

เป้าหมายของโครงการคือประเมินและปรับปรุงความมั่นคงปลอดภัยของเว็บไซต์ Alien Buu ที่ให้บริการผ่านโดเมน alienbuu.duckdns.org บน Azure Virtual Machine โดยครอบคลุมระบบปฏิบัติการ Linux, การเข้าถึง SSH, Firewall, Apache Reverse Proxy, TLS/HTTPS, Docker Compose, WordPress, Plugins/Themes, ฐานข้อมูล MariaDB, การจัดเก็บ Secrets, Logging, Backup/Recovery และการตรวจสอบหลังแก้ไข

การทดสอบอ้างอิงรายงานที่เจ้าของระบบระบุว่าได้รับอนุญาต
โดยเน้นตรวจสอบคอนฟิกและหลักฐานจากการเชื่อมต่อจริง
หลีกเลี่ยงการทดสอบแบบยิงคำขอปริมาณสูงซ้ำ เพราะในอดีตมีรายงานว่า ffuf และ WPScan สร้างโหลดจนเกิด Out-of-Memory (OOM) และทำให้ฐานข้อมูลหยุดให้บริการเป็นเวลานาน

## ใครเป็นผู้ใช้งาน และข้อมูลใดมีความสำคัญ

- **ผู้เข้าชมทั่วไป:** อ่านข้อมูลหลักสูตรและเนื้อหาสาธารณะ
- **ผู้ดูแลเว็บไซต์/ผู้แก้ไขเนื้อหา:** ใช้ WordPress Dashboard เพื่อจัดการเพจ สื่อ และส่วนเสริม
- **ผู้ดูแลระบบเซิร์ฟเวอร์:** เข้าถึง VM ผ่าน SSH และมีสิทธิ์จัดการระบบปฏิบัติการ Docker และคอนฟิกบริการ
- **ข้อมูลและทรัพย์สินสำคัญ:** เนื้อหาเว็บไซต์และไฟล์สื่อ, ฐานข้อมูล WordPress, บัญชีและ Session ของผู้ดูแล, รหัสผ่านฐานข้อมูลและ Docker, กุญแจ SSH, ไฟล์ wp-config.php, คีย์/Salts ของ WordPress, ไฟล์สำรองข้อมูล .wpress, คอนฟิกเว็บเซิร์ฟเวอร์ และ Log ที่อาจมีข้อมูลลับ

จากข้อมูลที่ได้รับ ยังไม่มีบัญชีรายการข้อมูลส่วนบุคคลในฐานข้อมูลครบถ้วน
จึงไม่สรุปว่าระบบเก็บข้อมูลส่วนบุคคลประเภทใดบ้าง
นอกเหนือจากข้อมูลบัญชีและข้อมูลที่จำเป็นต่อการจัดการเว็บไซต์

## เกณฑ์ความสำเร็จของระบบ

1. ผู้ใช้เข้าถึงเว็บไซต์ผ่าน HTTPS ด้วยโดเมนที่ถูกต้องและใบรับรองที่ตรวจสอบได้
2. HTTP ถูกเปลี่ยนเส้นทางไป HTTPS และมีการพิจารณาบล็อกการเข้าถึงผ่าน IP โดยตรง
3. พาธไฟล์สำรองและไฟล์ตั้งค่าที่มีความลับต้องไม่สามารถเข้าถึงจากอินเทอร์เน็ตได้
4. XML-RPC และการเปิดเผยรายชื่อผู้ใช้ผ่าน REST API ถูกปิดกั้นตามข้อกำหนดของระบบ
5. SSH, sudo, Firewall, WordPress roles, Database privileges และ Docker secrets ถูกจำกัดตามหลัก Least Privilege
6. อัปเดตและตรวจสอบ dependencies/Container images พร้อมหลักฐานจากเครื่องมือ

7. มี Backup ที่เก็บแยกจากเครื่องจริงและผ่านการทดสอบ Restore
8. มีค่าประสิทธิภาพ การเฝ้าระวัง แผนรับมือเหตุการณ์ และค่าใช้จ่ายที่วัดหรือยืนยันได้

เกณฑ์บางข้อยังไม่มีหลักฐานยืนยันผลสำเร็จ เช่น การทดสอบ Restore, RPO/RTO, Benchmark แบบ Median/p95/p99 และค่าใช้จ่ายจริง จึงต้องคงสถานะเป็น “ยังไม่ยืนยัน” จนกว่าจะมีผลทดสอบ

## สรุปความเสี่ยงหลักและแนวทางที่เลือก

การเปลี่ยนแปลงสำคัญล่าสุดคือ Apache บน Host ทำหน้าที่ Reverse Proxy ไปยัง WordPress Container ที่ 127.0.0.1:8080 ได้แล้ว และ WordPress URL ถูกปรับเป็น HTTPS แต่ผลตรวจรอบเดียวกันพบความเสี่ยงสูงที่พาธ /wp-content/ai1wm-backups/ ตอบ 200 OK อีกครั้ง นอกจากนี้ยังมี Header เปิดเผยเวอร์ชัน, ขาด HSTS, การเข้าผ่าน HTTPS ด้วย IP ตรงยังได้ 200 OK, รหัสผ่านยังปรากฏใน Docker Environment Metadata, มีความเสี่ยงด้านสิทธิ์ sudo และฐานข้อมูล และ MariaDB image พบ CVEs ในไบนารี gosu

แนวทางระยะสั้นคือปิดกั้นพาธสำรองข้อมูลที่ชั้น Reverse Proxy และตรวจซ้ำกับไฟล์จริงใน Container; จากนั้นจัดการ Secrets, Header, HSTS และ Default VirtualHost อย่างระมัดระวัง โดยสำรองคอนฟิกเดิม ตรวจ apache2ctl configtest ก่อน Reload และยืนยันผลหลังเปลี่ยนทุกครั้ง ไม่ควรนำชุดคำสั่งที่เขียนทับ VirtualHost ทั้งไฟล์ไปใช้บน Production โดยตรงโดยไม่ตรวจความแตกต่างและแผนย้อนกลับ

# 02 — VPS & Environment Specification

## ผู้ให้บริการ VPS, CPU, RAM, Storage, Network

- **ผู้ให้บริการ:** Azure Virtual Machine ตามข้อมูลของเจ้าของระบบและชื่อ Kernel 7.0.0-1017-azure ในรายงาน
- **ชื่อเครื่อง:** Alien-VM
- **IPv4 ที่รายงานระบุ:** 70.153.140.225
- **โดเมน:** alienbuu.duckdns.org ใช้ Dynamic DNS ของ DuckDNS
- **CPU/vCPU, ขนาดดิสก์, ชนิด Storage, throughput และแผน Network:** ยังไม่มีข้อมูลยืนยันจากหลักฐานที่ส่งมา จึงไม่ใส่ตัวเลขคาดเดา
- **หน่วยความจำ:** รายงานล่าสุดระบุ RAM ว่างประมาณ 2,630 MiB ณ เวลาตรวจ และ Swap ประมาณ 2,000 MiB; ค่านี้เป็น snapshot ขณะตรวจ ไม่ใช่ผลทดสอบทรัพยากรในช่วงโหลดสูง
- **ประวัติความเสถียร:** รายงาน Pentest ก่อนหน้าอธิบายว่าเคยเกิด OOM Kill หลังการสแกนที่ส่งคำขอจำนวนมาก ในช่วงดังกล่าวมี RAM ประมาณ 841 MiB และไม่มี Swap ทำให้ MariaDB ถูกหยุดหลายครั้งรวมช่วงหยุดบริการประมาณ 16 ชั่วโมง 46 นาที เหตุการณ์นี้เป็นประวัติในเดือนตุลาคม ไม่ใช่หลักฐานว่าปัญหาเดิมยังเกิดขึ้นอยู่ในปัจจุบัน

## Ubuntu Version และระยะเวลาการสนับสนุน

รายงานระบุ Host เป็น Ubuntu 24.04 LTS พร้อม Kernel 7.0.0-1017-azure และมีการใช้ Debian-based Apache/PHP ใน WordPress Container แยกจาก Host ตาม Banner ที่เห็นภายนอก Canonical ระบุ Ubuntu 24.04 LTS มี Standard Security Maintenance ถึงเดือนพฤษภาคม 2029 และสามารถขยายความคุ้มครองผ่าน Ubuntu Pro/ESM ถึงเดือนพฤษภาคม 2034 ตามเงื่อนไขบริการของ Canonical (Ubuntu release cycle)

การที่ระบบปฏิบัติการยังอยู่ในช่วงสนับสนุนไม่ได้ยืนยันว่าแพ็กเกจทุกตัวได้รับ Patch ล่าสุดแล้ว รายงานเก่าบันทึกว่า ESM Apps ยังไม่ได้เปิดใช้งานและมี Security Updates ที่เกี่ยวข้องบางส่วน ต้องตรวจ apt/Ubuntu Pro status อีกครั้งก่อนสรุปสถานะ Patch ณ วันส่งงาน

## Domain, DNS, IPv4/IPv6

รายงานล่าสุดยืนยันว่า DNS ของ alienbuu.duckdns.org ชี้ไปยัง IPv4 70.153.140.225 ถูกต้อง ส่วนหลักฐานเรื่อง AAAA/IPv6 DNS และการเข้าถึงเว็บไซต์ผ่าน IPv6 ยังไม่ครบถ้วน แม้ UFW มีรายการกฎสำหรับ IPv4 และ IPv6 จึงควรแยกการยืนยัน DNS record ออกจากการยืนยันการฟังพอร์ตและการเข้าถึงจริง

ไม่พบ Cron Job สำหรับอัปเดต DuckDNS ในการตรวจล่าสุด หาก Public IP ของ VM เปลี่ยน โดเมนอาจชี้ผิดปลายทางได้ ต้องยืนยันว่ามีระบบอัปเดต IP จากตำแหน่งอื่นหรือไม่ก่อนเพิ่ม Job ซ้ำ เพื่อไม่ให้เกิดการอัปเดตซ้อนหรือเผยแพร่ Token

## ข้อจำกัดด้านงบประมาณและ Availability

ยังไม่มีเอกสารค่า VM, Managed Disk, Bandwidth/Egress, Backup, Domain หรือบริการเสริมรายเดือน จึงไม่สามารถคำนวณค่าใช้จ่ายจริงได้ เช่นเดียวกันยังไม่มี SLA/Availability target ที่ประกาศไว้ การออกแบบปัจจุบันดูเป็นเครื่อง VM เดียว จึงควรพิจารณาความเสี่ยง Single Point of Failure และวางแผน Backup/Restore ให้เหมาะกับงบประมาณของโครงการ

# 03 — Architecture & Technology Decisions

## แผนภาพ Architecture และ Data Flow

### สถาปัตยกรรมล่าสุดตามรายงาน 29 ตุลาคม 2569 เวลาโดยประมาณ 22:15 น. ประเทศไทย

```
ผู้ใช้งานอินเทอร์เน็ต
        |
        | HTTPS :443 / HTTP :80
        v
DNS: alienbuu.duckdns.org -> 70.153.140.225
        |
        v
Azure VM / Ubuntu 24.04 Host (Alien-VM)
        |
        +-- UFW Firewall: 22 (LIMIT), 80 (ALLOW), 443 (ALLOW)
        |
        +-- Apache Host: TLS termination / HTTP redirect / Reverse Proxy
                |
                | ProxyPass -> http://127.0.0.1:8080/
                v
        Docker WordPress Container (Apache + PHP 8.3)
                |
                | Docker internal network
                v
        MariaDB Container
```

แผนภาพนี้แสดงเส้นทางที่รายงานล่าสุดยืนยันว่าคำขอจากภายนอกเข้าถึง Docker Container จริง โดย Banner ภายนอกแสดง Apache/2.4.69 (Debian) และ WordPress URL (siteurl/home) ถูกปรับเป็น https://alienbuu.duckdns.org ตามรายงานทั้งใน Container และ Host อย่างไรก็ตาม รายงานยังพบ MariaDB/บัญชีฐานข้อมูลฝั่ง Host และส่วนประกอบเดิมบางรายการ จึงต้องยืนยันว่ามีบริการซ้ำใดที่ยังจำเป็นก่อนหยุดหรือถอนออก

## Native หรือ Docker Compose

สถานะล่าสุดเลือกใช้ **Docker Compose สำหรับ WordPress และ MariaDB โดย Apache บน Host ทำหน้าที่ Reverse Proxy และจัดการ TLS** การเชื่อม Proxy เข้าสู่ Container ปิดข้อค้นพบ F-36 ที่เดิมพบ Docker เป็น Ghost Stack ไม่รับทราฟฟิกภายนอกจริง

ข้อดีคือแยกแอปกับฐานข้อมูลออกจาก Host ได้ในระดับหนึ่งและทำให้การสร้างสภาพแวดล้อมซ้ำได้ง่ายขึ้น

ส่วนข้อแลกเปลี่ยนคือมีความซับซ้อนเพิ่มขึ้นจากการจัดการ Network, Bind Mount, Environment Variables, Image Updates, Header ที่ส่งผ่าน Proxy และบริการเดิมบน Host ที่อาจยังทำงานซ้ำซ้อน การเลือก Docker จึงไม่ได้หมายความว่าความเสี่ยงด้านสิทธิ์และ Secrets หายไปโดยอัตโนมัติ

## Nginx หรือ Apache

หลักฐานล่าสุดระบุว่าใช้งาน Apache เป็น Reverse Proxy บน Host และใช้ Apache/PHP ภายใน WordPress Container ไม่มีหลักฐานว่ามี Nginx ในเส้นทางให้บริการจริง จึงไม่ควรเขียนว่า Nginx เป็นส่วนหนึ่งของสถาปัตยกรรม การเลือกคง Apache ช่วยลดการเปลี่ยนส่วนประกอบในช่วงที่ระบบออนไลน์อยู่ แต่ต้องจัดการ Header, Proxy Rules, Default VirtualHost, Redirect และการบล็อกไฟล์สำรองให้ถูกต้องทั้งชั้น Host และ Container

## PHP-FPM, MariaDB, Reverse Proxy และ Cache

รายงานระบุ PHP 8.3.36 ผ่าน Header ของ Container แต่ยังไม่ได้ให้หลักฐานเพียงพอที่จะยืนยันรูปแบบ PHP-FPM หรือ Web SAPI อย่างละเอียด จึงควรตรวจจาก Container Runtime Configuration ก่อนระบุว่าเป็น PHP-FPM ส่วน MariaDB Container อยู่ใน Docker internal network ตามรายงาน และไม่ควรเปิดพอร์ตฐานข้อมูลออกสู่ Internet โดยไม่จำเป็น

ProxyPass และ ProxyPassReverse ถูกเพิ่มเข้า VirtualHost พอร์ต 443 และส่ง Header X-Forwarded-Proto: https / X-Forwarded-Port: 443 รายงานยังไม่ได้ยืนยันว่ามี Page Cache หรือ Object Cache ที่ใช้งานและวัดผลได้ จึงไม่อ้างว่ามี Cache ประสิทธิภาพสูงแล้ว

## เหตุผลที่เลือก พร้อมข้อแลกเปลี่ยนของทางเลือกอื่น

แนวทางปัจจุบันลดการเปลี่ยนโครงสร้างโดยยังคง Apache และ TLS บน Host แล้วส่งทราฟฟิกไปยัง Container ข้อแลกเปลี่ยนคือมีขอบเขตการควบคุมหลายชั้น ทำให้กฎเดิมบน Host อาจไม่ถูกใช้หลังเปิด Proxy ดังตัวอย่าง F-10 ที่กลับมาตอบ 200 OK การปิดกั้นข้อมูลอ่อนไหวจึงต้องตรวจสอบเส้นทางคำขอตั้งแต่ Host, Proxy จนถึง Container ไม่ใช่ตรวจเฉพาะคอนฟิกชั้นเดียว

# 04 — Threat Model & Attack Surface

## ทรัพย์สินที่ต้องปกป้อง (Assets)

1. ความพร้อมให้บริการเว็บไซต์และฐานข้อมูล (Availability)
2. ความถูกต้องของเนื้อหา เพจ สื่อ และการตั้งค่า WordPress (Integrity)
3. บัญชีผู้ดูแล, Session, WordPress Salts, SSH Keys, sudo credentials และ Database credentials (Confidentiality)
4. ไฟล์สำรอง .wpress, wp-config.php, Docker configuration/Environment Variables และไฟล์ Log
5. สิทธิ์และการควบคุมของ Host, Docker Runtime และบัญชีฐานข้อมูล

## จุดเข้าถึงระบบและ Trust Boundaries

- Internet ไปยัง DNS/IPv4 และพอร์ต 80/443
- Internet ไปยังหน้า Login ของ WordPress และปลั๊กอินที่เปิด Endpoint
- พาธ wp-content/ai1wm-backups/ ที่รายงานล่าสุดพบ HTTP 200 OK
- ผู้ดูแลระบบผ่าน SSH พอร์ต 22 และสมาชิกกลุ่ม sudo
- ขอบเขตระหว่าง Host Apache กับ Docker WordPress ผ่าน 127.0.0.1:8080
- ขอบเขตระหว่าง WordPress Container กับ MariaDB Container ผ่าน Docker Network
- ขอบเขตข้อมูลใน Docker Environment Metadata, Bind Mounts และไฟล์ Log

## Threat Actors, Entry Points และ Attack Paths

Threat actors ที่ต้องพิจารณา ได้แก่ ผู้โจมตีจากอินเทอร์เน็ตที่ค้นหาพาธสำรองหรือ Endpoint ที่เปิดอยู่ ผู้พยายามเดารหัสผ่าน ผู้ใช้ที่ได้รับสิทธิ์ภายในมากเกินจำเป็น และผู้ที่สามารถเข้าถึง Docker/Host Metadata ได้โดยไม่ได้รับอนุญาต เส้นทางโจมตีที่มีหลักฐานเกี่ยวข้อง ได้แก่ การเข้าถึงพาธสำรองผ่าน Reverse Proxy, การเก็บข้อมูลเวอร์ชันจาก Server Header, การใช้บัญชีหรือ Session ที่ยังไม่หมุนเวียน และการใช้ Secrets ที่ถูกเปิดเผยใน Environment Metadata หรือ Log

## ผลกระทบด้าน Confidentiality, Integrity, Availability

- **Confidentiality:** หากไฟล์ Backup ดาวน์โหลดได้ อาจเปิดเผยเนื้อหาเว็บไซต์และข้อมูลฐานข้อมูล; Secrets ที่ถูกเปิดเผยอาจนำไปสู่การเข้าถึงฐานข้อมูลหรือบริการอื่น
- **Integrity:** หากบัญชี WordPress, SSH หรือ Database ถูกยึด อาจแก้ไขเนื้อหา ติดตั้งโค้ดที่เป็นอันตราย หรือแก้การตั้งค่าระบบ

- **Availability:** การสแกนที่ใช้คำขอจำนวนมากหรือการโจมตีแอปพลิเคชันอาจใช้ RAM/CPU/Database จนระบบหยุดให้บริการ ดังที่มีประวัติ OOM ในรายงานก่อนหน้า

## ความเสี่ยงก่อนและหลังการควบคุม

| ประเด็น | ก่อนการแก้ไขล่าสุด | สถานะหลังแก้ไขล่าสุด | ความเสี่ยงคงเหลือ |
|---|---|---|---|
| Proxy ไป Docker | Docker ไม่ได้รับทราฟฟิกจริง | เชื่อม Proxy สำเร็จ | ต้องทบทวนกฎทุกชั้นหลัง Proxy |
| XML-RPC | Endpoint ตอบรับคำขอ | POST /xmlrpc.php ได้ 403 | ทดสอบซ้ำหลังการเปลี่ยนคอนฟิก |
| HTTP -> HTTPS | HTTP เคยตอบ 200 โดยไม่ Redirect | Redirect เป็น 302 | ยังเป็น Temporary Redirect; ตรวจทุก VirtualHost |
| Backup path | Host เคยบล็อกเป็น 403 | พาธโฟลเดอร์ตอบ 200 | **เร่งด่วน: บล็อกที่ Host และ Container และตรวจไฟล์จริง** |
| Security Headers | มีเพียงบางส่วน | ยังขาด HSTS และมี Banner | ต้องตั้งค่าและตรวจผลหลังแก้ |
| Secrets | พบข้อมูลรับรองใน Log/Config ตามรายงานเก่า | Docker Metadata ยังมีตัวแปรรหัสผ่าน | ต้องหมุนเวียน Secrets และเปลี่ยนวิธีส่งค่า |

# 05 — OS & Infrastructure Hardening

## SSH Key, Least Privilege, sudo

ผลตรวจล่าสุดระบุ PermitRootLogin no ซึ่งถือเป็นการควบคุมที่ดำเนินการแล้ว อย่างไรก็ตาม ยังมีประเด็นค้างที่ต้องตรวจต่อ ได้แก่ กลุ่ม sudo มี 9 บัญชีตามรายงาน, SSH keys ประมาณ 12 รายการที่ไม่มีข้อจำกัด from=, ค่า SSH Forwarding ยังเปิดบางประเภทและ MaxAuthTries เดิมเป็น 6, มีคอนฟิก sshd_config.d ที่ขัดแย้ง และพบกฎ alien ALL=(ALL) NOPASSWD:ALL ใน sudoers ตามรายงานล่าสุด

ควรตรวจสอบเจ้าของบัญชีและความจำเป็นทางงานแต่ละบัญชี ลดสิทธิ์ที่ไม่จำเป็น เก็บ SSH Key ให้เป็นรายบุคคล ปิด Forwarding เฉพาะเมื่อยืนยันว่าไม่มีระบบที่ต้องใช้ และแก้คอนฟิกที่ขัดแย้งในช่วง Maintenance Window พร้อมมี Console/ช่องทางกู้คืนก่อน Reload SSH เพื่อป้องกันการล็อกตัวเองออกจากเครื่อง

## Firewall และการปิดบริการที่ไม่จำเป็น

UFW ทำงานอยู่ โดยค่าเริ่มต้นปฏิเสธการเชื่อมต่อขาเข้า จำกัดพอร์ต 22 และอนุญาตพอร์ต 80/443 ตามผลตรวจล่าสุด ให้รักษาหลักการเปิดเฉพาะบริการที่จำเป็น และยืนยันว่า 3306/MariaDB รวมทั้งพอร์ตของ Container ไม่ได้เปิดเผยออกสู่ Public Interface โดยตรง คำว่า UFW เปิดใช้งานไม่ได้รับประกันว่ากฎของ Azure Network Security Group หรือ Docker networking จะสอดคล้องกันทั้งหมด จึงควรตรวจทั้งสองชั้น

## Security Updates, AppArmor และ System Logging

รายงานระบุ Kernel ทางการ 7.0.0-1017-azure และระบุว่า CVE Kernel ที่ค้นพบเดิมได้รับการแก้ไขแล้ว แต่ต้องตรวจ Patch status รอบส่งมอบอีกครั้ง รายงานก่อนหน้านี้พบ Lynis Hardening Index ที่ 66/100 ซึ่งบ่งชี้ว่ายังมีพื้นที่ปรับปรุง ไม่ใช่การรับรองว่าระบบปลอดภัยทั้งหมด

สถานะ AppArmor และความสมบูรณ์ของ Log Rotation/การเก็บ Log ระยะยาวยังไม่มีหลักฐานสรุปครบถ้วน ควรบันทึกสถานะบริการและ Profile ที่บังคับใช้ แยก Log ของ SSH, sudo, Apache Host, WordPress Container, Fail2ban และระบบฐานข้อมูล พร้อมจำกัดสิทธิ์อ่าน Log เพราะรายงานเก่าระบุว่ามีข้อมูลรับรองปรากฏใน Log บางส่วน

## การจัดการผู้ดูแลระบบและการเข้าถึง VPS

ให้จัดทำบัญชีรายชื่อผู้ดูแลระบบพร้อมเหตุผลการใช้งาน ผู้รับผิดชอบ และวันที่ทบทวนสิทธิ์ โดยใช้หลัก Least Privilege และยืนยันว่าการเข้าถึง Azure Portal/Subscription ถูกจำกัดตามบทบาทด้วย ข้อมูลที่ระบุว่ามีกลุ่ม sudo 9 บัญชีและ SSH keys 12 รายการเป็นผลตามรายงานตรวจล่าสุด ไม่ควรสรุปว่าทุกบัญชีเป็นบัญชีไม่จำเป็นจนกว่าจะตรวจสอบกับเจ้าของระบบ

# 06 — Network, DNS, TLS & Edge Security

## DNS และการตั้งค่า HTTPS/TLS

รายงานล่าสุดยืนยัน DNS ของ alienbuu.duckdns.org ชี้ตรงไปยัง 70.153.140.225
และเว็บไซต์ใช้ใบรับรอง Let's Encrypt สำหรับโดเมนดังกล่าว ตามหลักฐาน TLS ล่าสุด testssl.sh 3.3dev ให้เกรดรวม **A+ คะแนน 96** และผลก่อนหน้านี้ยืนยันว่ารองรับ TLS 1.2/1.3 อย่างไรก็ตาม เกรด A+ ไม่ได้หมายถึงไม่มีข้อบกพร่องทั้งหมด เพราะยังพบ Header ที่เปิดเผยเทคโนโลยี ขาด HSTS และมีคำเตือน LUCKY13/BREACH จากเครื่องมือ
ซึ่งต้องตรวจความหมายและเงื่อนไขการใช้งานเพิ่มเติมก่อนระบุว่าโจมตีได้จริง

ไฟล์หลักฐานรอบนี้ไม่ระบุวันหมดอายุใบรับรองในส่วนผลสรุป
จึงควรตรวจค่าปัจจุบันจากใบรับรองและระบบต่ออายุอัตโนมัติก่อนรายงานวันหมดอายุ
หากอ้างวันหมดอายุจากรายงานเก่า ให้ระบุว่าเป็นค่าจากการตรวจรอบเก่า ไม่ใช่ยืนยันสถานะล่าสุด

## Reverse Proxy และ Trusted Proxy Headers

Apache Host ถูกตั้ง ProxyPass / http://127.0.0.1:8080/ และ ProxyPassReverse พร้อมส่ง X-Forwarded-Proto: https และ X-Forwarded-Port: 443 การทำงานของ Proxy ยืนยันจาก Banner ของ Container ที่แสดงภายนอกแล้ว แต่ควรทดสอบว่าฝั่ง WordPress เชื่อถือเฉพาะ Proxy ที่ถูกต้อง และไม่มีการเชื่อ Header จากคำขอภายนอกโดยตรงโดยไม่จำเป็น ควรตรวจ URL ที่สร้าง, Secure Cookies, Redirect loops และการเข้าสู่ระบบหลังเปลี่ยนคอนฟิก

## WAF, Rate Limiting และ DDoS Protection

รายงานระบุการใช้งาน Wordfence WAF, Limit Login Attempts และ Fail2ban jails สำหรับ sshd และ wp-login การควบคุมเหล่านี้ช่วยลดความเสี่ยงการเดารหัสผ่าน
แต่ยังไม่มีหลักฐานว่ามีบริการ DDoS Protection หรือ WAF ที่ขอบเครือข่ายระดับ Cloud เพิ่มเติม จึงไม่ควรระบุว่าป้องกัน DDoS ได้ครอบคลุม

## จำกัดการเข้าถึง Origin Server ให้เหมาะสม

ผลตรวจล่าสุดระบุว่าคำขอผ่าน https://70.153.140.225/ ยังตอบ 200 OK และ HTTP เปลือยผ่าน IP ถูกเปลี่ยนเส้นทางแล้วแต่ยังเป็น 302 จึงควรกำหนด Default VirtualHost
ให้ไม่ส่งเว็บไซต์จริงเมื่อเข้าถึงด้วย IP ที่ไม่ใช่ Hostname ที่กำหนด ทดสอบทั้ง IPv4, IPv6 (หากเปิดใช้), โดเมนหลัก และโดเมนย่อยที่เกี่ยวข้อง ก่อนใช้ HSTS
ระยะยาวควรยืนยันว่าโดเมนย่อยทั้งหมดรองรับ HTTPS จริง และไม่เปิด includeSubDomains โดยไม่มีการสำรวจขอบเขตที่เกี่ยวข้อง

**ลำดับความสำคัญเร่งด่วน:** บล็อก /wp-content/ai1wm-backups/ ที่ชั้น Reverse Proxy และ Container; ยืนยันว่าไม่สามารถดูรายการไฟล์หรือดาวน์โหลดไฟล์สำรองได้ จากนั้นลบ/ย้าย Backup ออกจาก Document Root อย่างมีขั้นตอนและเก็บหลักฐานตามนโยบาย โดยห้ามถือว่า 200 OK ของไดเรกทอรีหมายถึงดาวน์โหลดไฟล์สำรองสำเร็จแล้วจนกว่าจะมีผลทดสอบเฉพาะไฟล์

# 07 — WordPress Application Hardening

## Core, Plugin และ Theme Updates

รายงานก่อนหน้าระบุการตรวจ Theme และ MU-Plugins ด้วย Semgrep, TruffleHog, Gitleaks และ PHP_CodeSniffer แต่ยังไม่มีหลักฐานรายการเวอร์ชัน WordPress Core, Plugin และ Theme ทั้งหมดพร้อมวันที่อัปเดตล่าสุด จึงต้องสร้าง Software Inventory แยกจากผลสแกนซอร์สโค้ด ควรถอดหรือปิดปลั๊กอินที่ไม่ได้ใช้งานหลังยืนยันว่าไม่เป็น dependency ของเว็บไซต์ โดยรายงานเดิมพบ Importer Plugins ที่ไม่ได้ใช้ตกค้างบน Host และรายงานล่าสุดยังระบุว่า AI1WM plugin ยังคง active ใน Container

## Administrator MFA และ Least Privilege

ยังไม่มีผลยืนยันว่า Administrator ทุกบัญชีเปิด MFA แล้ว ควรตรวจการรองรับ MFA ของระบบ WordPress/Identity Provider และบังคับใช้กับบัญชีสิทธิ์สูง พร้อมลดจำนวน Administrator และแยกบัญชีสำหรับงานประจำวันจากบัญชีดูแลระบบ
การกำหนดสิทธิ์ต้องทำตามหน้าที่จริงและตรวจสอบบัญชีที่ไม่ได้ใช้งาน

## File Permissions และการปิด Plugin/Theme Editor

รายงานล่าสุดยืนยันว่า wp-config.php ฝั่ง Host มีสิทธิ์ 640 root:www-data
แต่ยังไม่มีหลักฐานที่ครบถ้วนเกี่ยวกับสิทธิ์ไฟล์ใน Container ทุกพาธ หรือความเป็นเจ้าของไฟล์ใน Bind Mount จึงต้องตรวจทั้ง Host และ Container แยกกัน ค่าคอนฟิก DISALLOW_FILE_EDIT ยังไม่ปรากฏใน wp-config.php ของ Container ตามรายงาน ควรพิจารณาปิดการแก้ Theme/Plugin ผ่าน Dashboard หลังยืนยันว่าทีมมี Deployment/Recovery ช่องทางอื่นแล้ว และหลีกเลี่ยงการตั้ง DISALLOW_FILE_MODS แบบครอบคลุมโดยไม่วิเคราะห์ผลกระทบต่อการอัปเดต

## Login Protection, XML-RPC และ REST API

- POST /xmlrpc.php ตอบ 403 Forbidden ในการตรวจล่าสุด จึงถือว่าการเข้าถึง Endpoint ถูกบล็อกตามผลทดสอบนั้น
- GET /wp-json/wp/v2/users ตอบ 404 Not Found ตามรายงานล่าสุด
  จึงไม่พบการแสดงรายชื่อผู้ใช้ผ่าน Endpoint ที่ทดสอบนี้ แต่ยังไม่ใช่การยืนยันว่า REST API ทุก Route ถูกจำกัดอย่างถูกต้อง
- Fail2ban, Wordfence WAF และ Limit Login Attempts
  ถูกระบุว่าใช้งานอยู่สำหรับป้องกันการเดารหัสผ่าน
- ควรทดสอบ Login, Reset Password, MFA, บัญชีล็อกเอาต์, Role/Capability และ REST API ด้วยบัญชีผู้ใช้แต่ละระดับ

## ป้องกันช่องโหว่จาก Plugin และ Theme

รายงานล่าสุดระบุว่า All-in-One WP Migration (AI1WM) ยังคง active ใน Container และเคยมี secret_key ปรากฏใน Log รวมถึงมีประเด็น nopriv AJAX Endpoint จึงต้องประเมินว่า plugin ยังจำเป็นหรือไม่ อัปเดตเวอร์ชันที่ได้รับการสนับสนุน ตรวจ endpoint และหมุนเวียนคีย์ที่เกี่ยวข้อง การทดสอบเฉพาะจุดควรทำแบบจำกัดคำขอและไม่ใช้ Fuzzing ปริมาณสูงบน Production

นอกจากนี้ยังพบความเสี่ยง F-10 จากพาธ Backup กลับมาตอบ 200 OK ภายหลัง Proxy ถูกเชื่อมแล้ว ต้องทดสอบทั้งการเปิดดูพาธ การแสดง Directory Listing และการเข้าถึงไฟล์ .wpress ที่ทราบชื่ออย่างปลอดภัย โดยไม่ดาวน์โหลดข้อมูลจริงที่ไม่จำเป็นและไม่เผยแพร่ไฟล์ระหว่างรายงาน

# 08 — Database, Secrets & Data Protection

## Database ไม่เปิดรับ Internet โดยไม่จำเป็น

รายงานระบุว่า MariaDB Container ใช้ Docker internal network และไม่ควรเปิดพอร์ต 3306 สู่ Internet อย่างไรก็ตาม ผลตรวจเดิมยังระบุ MariaDB บน Host และบัญชี ra_wp มี ALL PRIVILEGES รวมถึง local_infile = ON ข้อมูลดังกล่าวต้องตรวจว่า instance ฝั่ง Host
ยังทำงานและยังถูกใช้อยู่หรือไม่ ห้ามหยุดหรือลบฐานข้อมูลฝั่ง Host ก่อนตรวจ dependency, backup และระบุฐานข้อมูลที่เป็นแหล่งข้อมูลจริงของเว็บไซต์

## แยก Database User และจำกัดสิทธิ์

บัญชี WordPress ควรมีสิทธิ์เฉพาะฐานข้อมูลและคำสั่งที่ต้องใช้ตามรูปแบบการทำงานจริง การที่ ra_wp มี ALL PRIVILEGES บน Host เป็นข้อค้นพบที่ควรลดสิทธิ์หลังพิสูจน์ dependency แล้ว ส่วน local_infile = ON ควรปิดหากไม่มีงานที่ต้องใช้
เนื่องจากอาจเพิ่มพื้นที่เสี่ยงเมื่อร่วมกับการเข้าถึงที่ไม่เหมาะสม
การแก้ต้องทดสอบบนสำเนาก่อนเพื่อไม่ให้ Import/งานดูแลที่จำเป็นเสียหาย

## ป้องกันการรั่วไหลของ Credentials

รายงานใหม่ยืนยันว่าชื่อตัวแปร WORDPRESS_DB_PASSWORD, MARIADB_PASSWORD และ MARIADB_ROOT_PASSWORD ยังมีค่าอยู่ใน Docker Environment Metadata ในรูปแบบ Plaintext แม้จะไม่เปิดเผยค่าจริงไว้ในรายงานนี้ การมีค่าใน Metadata หมายความว่าผู้ที่มีสิทธิ์ตรวจ Docker Container/Inspect อาจอ่านค่าได้ตามสิทธิ์ที่มี ควรหมุนเวียนรหัสผ่านที่มีความเสี่ยง ใช้วิธีจัดการ Secrets ที่เหมาะสมกับสภาพแวดล้อม และจำกัดสิทธิ์เข้าถึง Docker Daemon เพราะผู้ใช้ที่ควบคุม Docker ได้มักมีอำนาจสูงบน Host

รายงานก่อนหน้าระบุว่ามีรหัสผ่าน sudo และคีย์ของ AI1WM ปรากฏใน Log มาก่อน การไม่มี Secrets ในผลสแกนซอร์สโค้ดบางชุดไม่ได้ยืนยันว่าไม่มีข้อมูลรับรองใน Log, Docker Metadata หรือไฟล์นอกขอบเขตการสแกน จึงต้องหมุน Credentials โดยพิจารณาประวัติการเปิดเผยจริง

## File Permissions, Encryption และการจัดการข้อมูลสำคัญ

ให้จัดเก็บ .env, wp-config.php, คีย์ TLS, Backup และไฟล์ที่มีข้อมูลรับรองด้วยสิทธิ์เท่าที่จำเป็น แยก Secrets จากซอร์สโค้ดและ Log ห้ามใส่ค่าจริงในรายงานหรือ Git
และกำหนดขั้นตอนหมุนเวียนเมื่อมีเหตุสงสัยว่ารั่วไหล
ยังไม่มีหลักฐานระบุว่าข้อมูลสำรองถูกเข้ารหัสและเก็บนอกเครื่องจริง
จึงต้องยืนยันการเข้ารหัสระหว่างส่งและขณะจัดเก็บตามความสามารถของแพลตฟอร์มและข้อจำกัดของทีม

# 09 — Deployment, CI/CD & Supply Chain Security

## การติดตั้งที่ทำซ้ำได้

การใช้งาน Docker Compose ช่วยให้ระบุบริการและการเชื่อมต่อเป็นไฟล์คอนฟิกได้ แต่รายงานปัจจุบันไม่ได้แสดง Pipeline CI/CD ที่ทำงานอัตโนมัติหรือหลักฐานว่าการ Deploy ทั้งหมดทำซ้ำได้จาก Repository สะอาด ควรจัดเก็บ Compose File, คอนฟิก Proxy, PHP hardening, Version Inventory และขั้นตอน Restore ไว้ในระบบควบคุมเวอร์ชัน โดยไม่ commit Secrets จริง

## การตรึงเวอร์ชันและตรวจสอบ Dependencies

Trivy Image Scan รอบล่าสุดระบุว่า WordPress Image ที่สแกนไม่พบ CVE ภายใต้ขอบเขตและฐานข้อมูลที่เครื่องมือใช้ ขณะที่ mariadb:10.11 พบ 26 CVEs ในไบนารี gosu (1 รายการระดับ Critical และ 25 รายการระดับ High ตามรายงาน) การจัดระดับของ Finding F-38 ในรายงานเป็น Low สะท้อนการประเมินบริบทว่าตัวไบนารีไม่ใช่บริการที่เปิดรับเครือข่ายโดยตรง ไม่ได้ลบล้างความรุนแรงที่เครื่องมือรายงานไว้ ต้องแยก “Severity ของ CVE” ออกจาก “Risk rating ของข้อค้นพบในระบบ” ให้ชัดเจน

ควรตรวจว่า Image ที่ใช้งานมี Tag ที่เลื่อนได้หรือไม่ ระบุเวอร์ชัน/ค่า Digest เมื่อเหมาะสม อัปเดตเฉพาะหลังสำรองและทดสอบความเข้ากันได้ แล้วสแกนซ้ำก่อนและหลัง Deploy ส่วนรายงานเก่าที่ระบุ Trivy RootFS ไม่พบ OS vulnerabilities ใช้พารามิเตอร์และขอบเขตที่กำหนด เช่น --ignore-unfixed จึงไม่ควรตีความว่าทุกแพ็กเกจและทุก Image ปราศจากช่องโหว่

## การจัดการ Configuration และ Secrets

คอนฟิกในปัจจุบันต้องจัดการทั้ง Host Apache และ Container Apache/PHP รวมถึงเส้นทาง Bind Mount จาก /root/alien-buu-migration/ ตามรายงานล่าสุด การ Mount จาก /root/ ทำให้สิทธิ์และการดูแลไฟล์ซับซ้อน และอาจเกี่ยวข้องกับการทำงานภายใต้สิทธิ์สูง ควรวางแผนย้ายไปยัง Directory สำหรับ Application ที่มี Owner/Group และ Permission ชัดเจนหลังสำรองข้อมูล และปรับ Compose File ให้ตรงกับตำแหน่งใหม่

## การตรวจสอบก่อน Deploy, Rollback และ Change Control

ก่อนเปลี่ยนคอนฟิกให้เก็บสำเนาไฟล์เดิม บันทึก Diff ตรวจการตั้งค่า TLS/Proxy/Headers ตรวจ apache2ctl configtest และทดสอบเส้นทางหลักใน Staging หรือช่วงเวลาที่กำหนด ก่อน Reload Service ให้มีแผน Rollback และ Console/SSH สำรอง หลัง Deploy ให้ทดสอบหน้าเว็บ Login, Media, Redirect, Backup Path, XML-RPC, REST API, Cookies และ Logs

ห้ามคัดลอกคำสั่งที่เขียนทับไฟล์ VirtualHost ทั้งไฟล์จากรายงานตรวจสอบไปใช้ทันที

โดยไม่เปรียบเทียบคอนฟิกเดิม เพราะอาจลบ Directive สำคัญของระบบ รวมถึงอย่า Restart Container หรือเปลี่ยน Mount บน Production โดยไม่ทราบผลกระทบต่อ Session/Connection และมีแผนกู้คืน

## เพิ่ม Container Security หากเลือก Docker

- จำกัดผู้มีสิทธิ์ใช้ Docker Daemon และไม่ให้ผู้ใช้ทั่วไปเข้าถึง Metadata ที่มี Secrets
- หลีกเลี่ยง Plaintext password ใน Environment Metadata และหมุนเวียนรหัสผ่านที่ถูกใช้ไปแล้ว
- ใช้ Image จากแหล่งที่เชื่อถือ ตรวจ CVEs และกำหนดขั้นตอนอัปเดตอย่างสม่ำเสมอ
- ทบทวน Bind Mount และลดสิทธิ์เขียนในตำแหน่งที่แอปไม่ต้องเขียน
- ใช้ Network ภายในสำหรับ WordPress-to-Database และเปิดเผยเฉพาะพอร์ตที่จำเป็น
- ตรวจ Healthcheck, Restart Policy, Resource Limits และ Logs เพื่อจำกัดผลกระทบเมื่อ Container ผิดปกติ

# 10 — Monitoring, Logging & Incident Detection

## System, Web Server, PHP และ Authentication Logs

รายงานล่าสุดระบุ Log แยกสำหรับ ra_error.log, ra_access.log และ alienbuu_ssl_*.log และมี Fail2ban สำหรับ sshd กับ wp-login อย่างไรก็ตาม ยังไม่มีหลักฐานว่ารวม Log ไปยัง Central Log Server หรือมีการเก็บรักษาแบบป้องกันการแก้ไข รายงานประวัติระบุว่าเคยมีข้อมูลรับรองใน auth.log และ secret_key ของ AI1WM ใน Log จึงต้องตรวจสิทธิ์ของ Log, Rotation, Retention และหมุนเวียนค่าที่เคยเปิดเผย

เมื่อใช้ Docker ต้องเก็บ Log จากทั้ง Apache Host และ Container ให้สัมพันธ์กัน โดยคำนึงถึงเวลา UTC/เวลาท้องถิ่นและ Request ID หากมี เพื่อช่วยไล่เหตุการณ์ระหว่าง Reverse Proxy, WordPress และ Database

## CPU, RAM, Disk และ Network Monitoring

รายงานมี snapshot RAM ว่างและ Swap ณ เวลาตรวจ แต่ไม่มีข้อมูลกราฟระยะยาว CPU, RAM peak, Disk usage, I/O, Network, Database Query Time หรือ Alert Threshold จึงยังไม่สามารถสรุปความพร้อมให้บริการต่อเนื่องได้ ควรตั้ง Alarm สำหรับพื้นที่ดิสก์เหลือน้อย, RAM/Swap สูงต่อเนื่อง, Container restart, Apache 5xx, Database unavailable และพฤติกรรม Login ผิดปกติ

## Alert สำหรับพฤติกรรมผิดปกติ

ควรสร้าง Alert ที่มี Action ชัดเจน เช่น การเข้าถึง Backup Path, จำนวน Login Failure สูง, การเปลี่ยนไฟล์สำคัญ, การสร้างบัญชี Administrator ใหม่, Container Image เปลี่ยนโดยไม่ผ่าน Change Control, Database Connection ผิดปกติ และการใช้ทรัพยากรสูงกว่าขีดจำกัด ต้องทดสอบการส่ง Alert ให้ผู้รับผิดชอบทราบจริง ไม่ใช่แค่ยืนยันว่ามีแพ็กเกจติดตั้งอยู่

## การเก็บ Log จากส่วนกลางและการจำกัดสิทธิ์เข้าถึง

แนะนำให้เก็บ Log สำคัญนอกเครื่องหรือในระบบที่ผู้ดูแลเว็บทั่วไปแก้ไขไม่ได้ โดยกำหนด Retention ที่สอดคล้องกับการเรียน/การตอบสนองเหตุการณ์ ต้องไม่เก็บรหัสผ่าน, Token, Session Cookie หรือ Secret โดยไม่จำเป็น และกำหนดวิธีเก็บหลักฐานที่คงความสมบูรณ์ เช่น timestamp, checksum, ผู้เก็บ และแหล่งที่มา

# 11 — Backup, Disaster Recovery & Business Continuity

## Backup Database, WordPress Files และ Configuration

ข้อมูลสำรองควรครอบคลุมฐานข้อมูล MariaDB, WordPress Files/Media, Compose File, Apache VirtualHost, TLS Renewal Configuration, PHP hardening, WAF/Fail2ban Configuration และข้อมูลจำเป็นต่อการสร้าง VM/บริการกลับคืน
ต้องกำหนดความถี่ตามการเปลี่ยนแปลงเนื้อหาและความสำคัญของเว็บไซต์

รายงานก่อนหน้าระบุว่าเคยพบไฟล์ .wpress ขนาดประมาณ 23.2 MB และรายงานล่าสุดยืนยันว่า URL ของไดเรกทอรี /wp-content/ai1wm-backups/ ตอบ 200 OK
แต่ผลล่าสุดไม่ได้พิสูจน์โดยตัวมันเองว่าไฟล์ Backup จริงยังอยู่หรือดาวน์โหลดได้สำเร็จ
จึงต้องตรวจไฟล์ภายในอย่างปลอดภัยและปิดกั้นการเข้าถึงสาธารณะทันที ไม่ควรนำ Backup ที่มีข้อมูลจริงมาแนบรายงานหรือเผยแพร่

## Off-site Backup และการป้องกันการลบหรือแก้ไข

ยังไม่มีหลักฐานยืนยันว่ามี Off-site Backup, Object Lock/Immutable Retention หรือสำเนาแยกบัญชี Cloud จึงไม่ควรระบุว่ามีแล้ว ควรเก็บสำเนาอย่างน้อยหนึ่งชุดนอก VM และจำกัดสิทธิ์ลบ/แก้ไข พร้อมเข้ารหัสและทดสอบว่าสามารถอ่านคืนได้ หากงบประมาณจำกัด ให้จัดลำดับความสำคัญของฐานข้อมูลและไฟล์สำคัญก่อน
พร้อมกำหนดผู้ถือครองข้อมูลสำรองอย่างชัดเจน

## Recovery Point Objective (RPO)

**ยังไม่ได้กำหนด RPO ที่ได้รับอนุมัติ** RPO คือปริมาณข้อมูลล่าสุดที่ยอมรับให้สูญหายได้เมื่อเกิดเหตุ หากเว็บไซต์มีการแก้เนื้อหาไม่บ่อย อาจกำหนดเป้าหมายจากความถี่ Backup ที่ทีมรับผิดชอบได้จริง แต่ค่าที่ใช้ส่งรายงานต้องได้รับความเห็นชอบจากเจ้าของระบบ
ไม่ควรตั้งตัวเลขสมมติว่าเป็นข้อกำหนดจริง

## Recovery Time Objective (RTO)

**ยังไม่ได้กำหนด RTO ที่ได้รับอนุมัติ** RTO คือเวลาสูงสุดที่ยอมรับได้ในการกู้บริการกลับมา ต้องกำหนดจากความสำคัญของเว็บไซต์และเวลาที่ทีมพร้อมกู้คืน
ไม่ควรใช้เวลาคาดการณ์เป็นผลทดสอบจริง

## สาธิต Restore จาก Backup จริง

ยังไม่มีหลักฐานทดสอบ Restore จาก Backup จริง การสาธิตควรทำบน VM/Environment แยก ไม่ทับ Production โดยบันทึกเวลาเริ่มและจบ ขั้นตอนกู้ฐานข้อมูลและไฟล์ การตรวจหน้าเว็บและสื่อ การทดสอบ Login/Permission และ checksum ของไฟล์สำคัญ
หลังทดสอบให้ลบหรือป้องกันข้อมูลสำเนาที่เกิดขึ้นตามนโยบาย รายงานจึงจะระบุผล RPO/RTO ที่วัดได้ตามการทดสอบจริง

# 12 — Security Validation & Adversarial Testing

## ตรวจสอบพอร์ตและบริการที่เปิดเผย

จากผลตรวจที่เจ้าของระบบส่งมา UFW อยู่ในสถานะ Active โดย Deny ขาเข้า, Limit พอร์ต 22 และ Allow พอร์ต 80/443 ส่วนรายงานการตรวจล่าสุดยืนยันการเข้าถึง HTTPS และ Reverse Proxy ไปยัง Container ได้จริง ควรตรวจยืนยัน Ports ทั้งจาก Host, Docker Port Binding และ Azure Network Security Group อีกครั้ง และตรวจว่า Database Port ไม่ได้เผยแพร่สู่ Internet โดยไม่จำเป็น

## ทดสอบ Authentication, Authorization และ Access Control

ผลที่ระบุในรายงานล่าสุด ได้แก่ XML-RPC ตอบ 403, REST API users endpoint ตอบ 404, มี Fail2ban/Wordfence/Limit Login Attempts แต่ยังไม่มีหลักฐานชุดทดสอบสิทธิ์ครบทุก Role, MFA, Password Reset, Session Revocation หรือการเข้าถึงข้อมูลด้วยบัญชีสิทธิ์ต่ำ จึงต้องทำ Test Case เพิ่มและบันทึกผลแยก Pass/Fail/Not Tested

## ตรวจสอบ TLS, HTTP Headers และการตั้งค่า

testssl.sh 3.3dev ได้ Grade A+ Score 96 แต่ยังพบ Server: Apache/2.4.69 (Debian), X-Powered-By: PHP/8.3.36 และไม่มี HSTS นอกจากนี้ HTTP ใช้ Redirect 302 และ HTTPS ผ่าน IP ตรงยังตอบ 200 OK ควรตรวจซ้ำหลังแก้ Header/VirtualHost/Redirect และตรวจว่า Header ที่ส่งจาก Container ถูกลบหรือเขียนทับที่จุดที่ถูกต้อง

ผล cURL รอบล่าสุดพบ GET /wp-content/ai1wm-backups/ ตอบ 200 OK ถือเป็นการถดถอยด้านการจำกัดพาธข้อมูลสำรอง ต้องทดสอบ Directory Listing และการเข้าถึงไฟล์จริงจากภายนอกอย่างจำกัดและได้รับอนุญาต โดยไม่ใช้ข้อมูลสำรองที่มีข้อมูลจริงเกินความจำเป็น

## สแกนช่องโหว่และตรวจสอบ Dependencies

| เครื่องมือ/วิธี | ขอบเขต/ผลตามรายงาน | ข้อควรตีความ |
|---|---|---|
| testssl.sh 3.3dev | TLS Grade A+, Score 96; พบ Banner, X-Powered-By, ไม่มี HSTS | ผลเกรดไม่ใช่หลักฐานว่าไม่มีความเสี่ยงทั้งหมด |
| Docker CLI / Inspect | พบ Environment Metadata ที่มีชื่อตัวแปรรหัสผ่านและ Bind Mount จาก /root/alien-buu-migration/ | อย่าเผยแพร่ค่าจริงในรายงาน |
| Trivy Image Scan | WordPress Image 0 CVEs ในผลสแกนชุดนี้; mariadb:10.11 มี 26 CVEs ใน gosu รวม 1 Critical, 25 High | สแกนใหม่หลังอัปเดต Image; แยก CVE Severity กับ Risk rating |
| Trivy OS/RootFS scan | รายงานเก่าไม่พบ OS vulnerabilities ภายใต้พารามิเตอร์ที่ใช้ | ไม่ครอบคลุมทุก Image/ทุก package หรือ CVE ที่ Ignore |
| Semgrep Pro | 293 rules, 0 Findings ในขอบเขต Theme/MU-Plugins ที่สแกน | ไม่ใช่การยืนยันทั้งระบบว่าไม่มี SQLi/RCE ทุกชนิด |
| TruffleHog / Gitleaks | 0 Secrets ใน Code Paths ที่สแกน | ไม่ครอบคลุม Logs, Docker Metadata หรือไฟล์นอก Scope |
| PHP_CodeSniffer | มีข้อสังเกตเรื่อง escaping และ include | ต้อง Review แก้ไขตามบริบทและทดสอบ Regression |
| Lynis | Hardening Index 66/100 | เป็นตัวบ่งชี้การปรับปรุง ไม่ใช่ Certification |
| cURL / DNS tools | ยืนยัน redirect, endpoint status และ DNS ตามที่รายงาน | รันซ้ำหลังการแก้ไขแต่ละรายการ |
| ffuf / WPScan | ในอดีตส่งคำขอจำนวนมากและสัมพันธ์กับ OOM ตามรายงาน | หลีกเลี่ยงการรันแบบ Aggressive บน |

| เครื่องมือ/วิธี | ขอบเขต/ผลตามรายงาน | ข้อควรตีความ |
|---|---|---|
| | | Production; ใช้ White-box/controlled test |

## ทดสอบเฉพาะระบบที่ได้รับอนุญาต โดยไม่ทำให้บริการเสียหาย

รายงานต้นทางระบุว่าเจ้าของระบบอนุญาตการตรวจสอบ อย่างไรก็ตาม ควรจำกัดการทดสอบให้ตรง Scope และทำในช่วงเวลาที่กำหนด การทดสอบพาธ Backup, Login, XML-RPC และ HTTP Headers ใช้คำขอจำนวนจำกัดได้ หลีกเลี่ยง Fuzzing และ CMS Scan แบบปริมาณสูงบน Production เพราะมีประวัติ OOM ให้ใช้ Staging, Snapshot หรือเครื่องจำลองเมื่อจะทดสอบ Load/Exploit ซ้ำ และหยุดทันทีเมื่อ CPU/RAM/Database เริ่มผิดปกติ

## หมายเหตุเรื่องจำนวนข้อค้นพบและระดับความรุนแรง

รายงานต้นทางเรียก Active Baseline ว่ามี 59 รหัส แต่ระบุช่วง F-01 ถึง F-43 และ S-01 ถึง S-17 ซึ่งเมื่อนับทุกช่วงจะได้ 60 รหัส อีกทั้งมีการกล่าวถึง F-44 ในส่วนบรรยายแต่ไม่พบแถวแยกใน Master Matrix และมีการระบุ F-01 ว่ารวมเข้ากับ F-10
จึงต้องกระทบยอดรหัสก่อนสรุปตัวเลขรวมในรายงานฉบับสุดท้าย

นอกจากนี้ Trivy รายงาน CVE 1 รายการระดับ Critical ใน gosu ของ MariaDB Image ขณะที่ Finding F-38 ถูกประเมินระดับ Low เนื่องจากการประเมินบริบทของบริการ จึงไม่ควรเขียนสรุปว่า “ไม่มี Critical CVE เลย” แต่ควรแยกความรุนแรงตามฐานข้อมูล CVE
ออกจากระดับความเสี่ยงของระบบเป้าหมาย

# 13 — Performance & Resource Benchmark

## Response Time: Median, p95, p99

ยังไม่มีผล Benchmark ที่รายงาน Median, p95 และ p99 ภายใต้ชุดคำขอและจำนวน Concurrent Users ที่ควบคุมได้ จึงไม่สามารถสรุป Response Time ของระบบในปัจจุบันได้ ควรทดสอบใน Staging หรือช่วงเวลาที่อนุมัติ พร้อมระบุเส้นทางที่วัด จำนวนคำขอ จำนวนผู้ใช้งานจำลอง และสถานะ Cache

## Requests per Second และ Error Rate

ยังไม่มีตัวเลข Requests per Second, HTTP 4xx/5xx Error Rate หรือ Timeout Rate ที่วัดจากการทดสอบมาตรฐาน ควรกำหนดปริมาณโหลดอย่างค่อยเป็นค่อยไปและติดตาม RAM/Swap/CPU/Database ควบคู่ หลีกเลี่ยงการใช้ ffuf หรือ WPScan เป็นเครื่องมือวัด Performance เนื่องจากรายงานเดิมชี้ว่าการสแกนปริมาณสูงเคยทำให้เกิด OOM

## CPU, RAM, Swap และ Database Query Time

ข้อมูลล่าสุดมีเพียง snapshot RAM ว่างประมาณ 2,630 MiB และ Swap ประมาณ 2,000 MiB ส่วนค่า CPU, Peak Memory, Swap activity, Disk I/O และ Database Query Time ยังไม่มีหลักฐานชุด Benchmark ต้องเก็บ Metrics ระหว่างทดสอบ ไม่สรุปจากภาพหน้าจอหรือค่าหนึ่งช่วงเวลาแทนผลการใช้งานต่อเนื่อง

## ทดสอบ Cache Hit/Miss และ Concurrent Requests

ไม่มีหลักฐานยืนยัน Page Cache/Object Cache ที่เปิดใช้งานพร้อมค่าการ Hit/Miss จึงต้องตรวจว่ามี Cache Layer จริงหรือไม่ก่อนออกแบบ Test Case ทดสอบอย่างน้อยหน้า Static, Dynamic/Logged-in และคำขอที่ไม่ควร Cache พร้อมวัดผลที่ระดับ Client และ Server

## เปรียบเทียบผลก่อนและหลังปรับแต่ง

ยังไม่สามารถจัดทำตารางเปรียบเทียบก่อน/หลังอย่างเป็นตัวเลขได้เพราะขาด Baseline ที่วัดภายใต้เงื่อนไขเดียวกัน ควรสร้าง Baseline ที่ปลอดภัยก่อนเปลี่ยน Cache, Worker Limit, PHP, Image หรือ Database และทำ Post-change Test ด้วยจำนวนคำขอ/เครื่องมือ/ระยะเวลาที่เทียบกันได้

# 14 — Incident Response & Operational Runbook

## ขั้นตอนรับมือเมื่อ WordPress ถูกเจาะ

1. **รับแจ้งและประเมิน:** บันทึกเวลา ผู้แจ้ง URL/บัญชี/อาการ และแยกเหตุเว็บแสดงเนื้อหาผิดปกติ, Backup Path เปิดเผย, Login ผิดปกติ หรือบริการล่ม
2. **จำกัดผลกระทบ:** หากพบ Backup หรือ Secret เปิดสาธารณะ ให้ปิดกั้น Endpoint ที่เสี่ยงผ่านการเปลี่ยนแปลงที่ได้รับอนุมัติ โดยหลีกเลี่ยงการปิด VM ทั้งเครื่องเว้นแต่จำเป็นต่อการหยุดความเสียหาย
3. **เก็บหลักฐาน:** เก็บ Apache Host/Container Logs, Authentication Logs, Docker Inspect/Compose Version, timestamp, รายการไฟล์ที่เปลี่ยน และ hash ของหลักฐานก่อนล้างไฟล์หรือ Rebuild
4. **ควบคุมบัญชี:** ปิด/ระงับบัญชีที่สงสัย หมุนรหัสผ่านและ Secrets ที่อาจรั่วไหล รวมถึง Database Credentials, WordPress Salts, SSH Keys และ Tokens ตามขอบเขตเหตุการณ์
5. **กำจัดสาเหตุ:** ตรวจ Plugin/Theme,บัญชี Administrator, Cron/Scheduled Tasks, Container Image, Bind Mount และไฟล์ที่เปลี่ยนผิดปกติ ใช้ Image/Backup ที่ตรวจสอบได้ ไม่คัดลอกไฟล์ที่อาจติดมัลแวร์กลับเข้าระบบ
6. **กู้คืนและยืนยัน:** กู้จาก Backup ที่สะอาดใน Environment แยก ทดสอบเนื้อหา, Login, Permissions, Redirect, Backup Path และ Logs ก่อนเปิดกลับ
7. **ทบทวนเหตุการณ์:** จัดทำ Timeline, Root Cause, ข้อมูลที่อาจได้รับผลกระทบ, การเปลี่ยนแปลงที่ทำ, ผลการตรวจซ้ำ และมาตรการป้องกันการเกิดซ้ำ

## การจำกัดผลกระทบและเก็บหลักฐาน

ห้ามลบ Log หรือ Backup ที่เกี่ยวข้องก่อนเก็บหลักฐาน
เว้นแต่การเปิดเผยข้อมูลกำลังดำเนินอยู่และจำเป็นต้องปิดกั้นทันที
ในกรณีเช่นนั้นให้บันทึกคอนฟิกเดิมและผลทดสอบก่อนแก้เท่าที่ทำได้
จำกัดสิทธิ์ผู้เข้าถึงหลักฐานและอย่าใส่ Password/Token จริงในรายงานที่เผยแพร่ต่อกลุ่มเรียน

## การหมุนเวียน Credentials และเพิกถอน Session

เมื่อมีหลักฐานว่า Credentials อาจรั่วไหล ให้เปลี่ยนรหัสผ่านจากช่องทางที่เชื่อถือได้
ไม่ใช่ผ่านเครื่องที่สงสัยว่าถูกยึด สร้างรหัสผ่านฐานข้อมูลใหม่และอัปเดตทั้งแอป/Secret Store
ให้ตรงกัน เปลี่ยน WordPress Salts เพื่อยกเลิก Session ตามผลกระทบ เพิกถอน SSH Keys/Token
ที่ไม่จำเป็น และตรวจบัญชี Administrator ที่เพิ่มใหม่
ทั้งนี้ต้องวางลำดับการเปลี่ยนเพื่อไม่ให้เว็บไซต์ใช้งานฐานข้อมูลไม่ได้โดยไม่ตั้งใจ

## ขั้นตอน Restore และตรวจสอบหลังเหตุการณ์

Restore ใน Environment แยกก่อนเสมอ เปรียบเทียบเวอร์ชันไฟล์และฐานข้อมูล ตรวจ checksum, ทดสอบหน้าเว็บไซต์, Media, Login/Role, การส่งอีเมล (หากใช้), HTTPS, Redirect, Security Headers, XML-RPC, REST API และ Backup Paths พร้อมตรวจว่า Secrets เก่าถูกยกเลิกแล้วก่อนนำระบบกลับออนไลน์

## ผู้รับผิดชอบและช่องทางแจ้งเตือน

รายงานต้นทางระบุเจ้าของระบบ/ผู้ดำเนินการหลักเป็น T และมีทีมตรวจสอบร่วม แต่ยังไม่มีรายชื่อผู้รับผิดชอบแยกด้าน Web, OS, Database, Cloud และการสื่อสารกับผู้ใช้ จึงควรจัดทำ Contact Matrix ที่มีผู้ตัดสินใจ, ผู้ปฏิบัติการ, ผู้อนุมัติ Deploy และช่องทางแจ้งเหตุ โดยไม่ใส่ข้อมูลส่วนตัวหรือช่องทางติดต่อที่ไม่จำเป็นลงในรายงานฉบับเผยแพร่

# 15 — Results, Cost, Residual Risks & Recommendations

## ผลลัพธ์เทียบกับเกณฑ์ที่กำหนด

| เกณฑ์ | ผลตามหลักฐานล่าสุด | สถานะ |
|---|---|---|
| Reverse Proxy ส่งทราฟฟิกไป Docker | ProxyPass/ProxyPassReverse ทำงานตามรายงานล่าสุด | ผ่านตามการตรวจรอบนี้ |
| WordPress URL ใช้ HTTPS | siteurl และ home ตั้งเป็น HTTPS ตามรายงาน | ผ่านตามรายงาน; ควรทดสอบ Regression หลังแก้ต่อ |
| HTTP เปลี่ยนไป HTTPS | พอร์ต 80 ส่ง 302 ไป HTTPS | บรรลุบางส่วน; ควรตรวจนโยบายถาวรและทุก VirtualHost |
| XML-RPC ปิดกั้น | POST ตอบ 403 | ผ่านตาม Endpoint ที่ทดสอบ |
| REST API User Enumeration | Endpoint ที่ทดสอบตอบ 404 | ผ่านเฉพาะ Endpoint/คำขอที่ทดสอบ |
| โฟลเดอร์ Backup ปลอดภัย | Path ตอบ 200 OK | **ไม่ผ่าน/เร่งด่วน**; ต้องบล็อกและทดสอบไฟล์จริง |
| Security Headers | ยังขาด HSTS และเผย Banner | ยังไม่ผ่านครบ |
| Secrets ปลอดภัย | มี Password-related Environment Variables ใน Docker Metadata | ยังไม่ผ่าน |
| Container Image Dependencies | MariaDB image มี 26 CVEs ใน gosu ตาม Trivy | ต้องประเมินและแก้ไข |
| Backup/Restore | ไม่มีหลักฐาน Off-site และ Restore Test | ยังไม่ยืนยัน |
| Performance Benchmark | ไม่มี Median/p95/p99/RPS/Error Rate ที่วัดครบ | ยังไม่ยืนยัน |
| Cost/Availability | ไม่มีค่าใช้จ่ายและ SLA ที่ยืนยัน | ยังไม่ยืนยัน |

## ค่าใช้จ่ายรายเดือนและภาระการดูแล

ยังไม่มีข้อมูล Azure Billing ที่ใช้คำนวณค่าใช้จ่าย VM, Storage, Network Egress, Snapshot/Backup, DNS หรือบริการเสริม จึงไม่ควรใส่ตัวเลขรายเดือนโดยคาดเดา สำหรับรายงานฉบับส่งงานควรแนบรายการค่าใช้จ่ายจาก Azure Cost Management ในช่วงเวลาที่ระบุ และบอกว่าเป็นค่าใช้จ่ายจริงหรือประมาณการ

ภาระการดูแลที่เห็นจากสถาปัตยกรรมคือดูแลทั้ง Apache Host และ Apache/PHP ใน Container รวมถึง WordPress, Database, Docker Images, Backup, TLS Renewal, DNS Update, Logs และ Monitoring จึงควรกำหนดผู้รับผิดชอบและรอบทบทวนชัดเจน

## ความเสี่ยงที่ยังเหลืออยู่

1. **High / เร่งด่วน:** wp-content/ai1wm-backups/ ตอบ 200 OK หลังเชื่อม Proxy ต้องปิดกั้นและยืนยันการเข้าถึงไฟล์สำรองจริง
2. **Medium–High:** รหัสผ่านใน Docker Environment Metadata และประวัติการเปิดเผย Credentials/Secrets ใน Log ต้องหมุนเวียนและจำกัดสิทธิ์ Docker
3. **High:** ข้อ F-22 ยังคงระบุว่าไม่ยืนยันการหมุนเวียนรหัสผ่าน sudo ที่เคยปรากฏใน Log และสิทธิ์ sudo/SSH กว้างเกินจำเป็นบางส่วน
4. **Medium:** AI1WM ยัง active, มีประเด็น nopriv endpoint/Secret Key เก่า และยังต้องทบทวนการใช้งาน
5. **Low–Medium:** Header เปิดเผยเวอร์ชัน Server/PHP, ขาด HSTS, CSP ยังไม่ครบ และ HTTPS ผ่าน IP ตรงได้
6. **Low ตาม Risk Rating ของรายงาน แต่มี CVE severity สูงในผลสแกน:** MariaDB gosu พบ 26 CVEs รวม 1 Critical; ต้องติดตามแพตช์และบริบทการใช้งาน
7. **Low–Medium:** ไม่มี DuckDNS updater ที่ตรวจพบ, มี Bind Mount ใต้ /root/, มีบัญชีฐานข้อมูลสิทธิ์กว้างและ local_infile=ON ใน Host ตามรายงาน
8. **ไม่สามารถจัดระดับอย่างครบถ้วน:** RPO/RTO, Off-site Backup, Restore Test, Monitoring Alert, Performance Benchmark, Availability และค่าใช้จ่ายยังไม่มีข้อมูลยืนยัน

## ข้อจำกัดของการทดสอบ

- รายงานฉบับนี้อาศัยหลักฐานจากไฟล์ที่เจ้าของระบบส่งมา ไม่ได้ตรวจเครื่องจริงซ้ำ ณ เวลาจัดทำเอกสาร
- Snapshot ทรัพยากรเป็นค่าขณะตรวจ ไม่แทนโหลดระยะยาว
- ผล Semgrep/TruffleHog/Gitleaks จำกัดอยู่ที่ Code Paths ที่สแกน ไม่ครอบคลุม Docker Metadata/Logs/ไฟล์นอกขอบเขต
- 200 OK ของ Backup Directory ไม่พิสูจน์ว่าไฟล์ .wpress ดาวน์โหลดได้ ต้องแยกการยืนยัน Directory Listing กับการเข้าถึงไฟล์จริง
- จำนวนข้อค้นพบไม่สอดคล้องกันทั้งหมด: รายงานระบุ 59 รหัส แต่ช่วง F-01..F-43 และ S-01..S-17 รวม 60 รหัส และมีการกล่าวถึง F-44 โดยไม่มีแถวแยกใน Master Matrix อีกทั้ง F-01 ระบุว่ารวมกับ F-10 ควรกระทบยอดก่อนรายงานยอดรวม
- การจัดระดับ F-38 เป็น Low เป็นการประเมินความเสี่ยงของระบบ ไม่ได้หมายความว่าเครื่องมือไม่พบ CVE Critical
- ไม่ได้จัดทำ Benchmark, Restore Test หรือ Cost Analysis ในหลักฐานชุดนี้ จึงไม่สร้างตัวเลขทดแทน

## แผนปรับปรุงระยะถัดไป

**P0 — ดำเนินการก่อนงานอื่น:** สำรองคอนฟิกปัจจุบัน; ปิดกั้น ai1wm-backups ทั้งที่ Reverse Proxy และ Container; ตรวจว่าไม่มี Directory Listing/ดาวน์โหลดไฟล์สำรอง; ย้ายไฟล์ Backup ออกจาก Web Root หรือเก็บในตำแหน่งที่ไม่เปิดเผย; ทดสอบหน้าเว็บและเก็บหลักฐานหลังแก้

**P1 — Secrets และสิทธิ์ผู้ดูแล:** ตรวจและหมุนเวียน Database Passwords, WordPress Salts, sudo credentials และ AI1WM secrets ที่อาจเปิดเผย; จำกัดสิทธิ์ Docker; ทบทวนสมาชิก sudo/SSH Keys/Forwarding; ตรวจบัญชี Database และ local_infile; ยืนยันว่าบริการ Host เดิมยังจำเป็นก่อนปิด

**P2 — Hardening Web/Network:** ลบ X-Powered-By, ลด Server Banner เท่าที่เหมาะสม, เพิ่ม Security Headers และวางแผน HSTS หลังยืนยันความพร้อมของ HTTPS/โดเมนย่อย, ปรับ HTTP Redirect ตามนโยบาย, จำกัด Default VirtualHost สำหรับ IP ตรง และตรวจ Trusted Proxy Headers

**P3 — Container และ Supply Chain:** ตรวจ/อัปเดต MariaDB Image ตามผล CVE, ตรวจ Version/Digest, ย้าย Bind Mount ออกจาก /root/ ด้วย Change Plan, ตรวจ Permission และตั้ง Resource Limits/Healthcheck

**P4 — Operational Readiness:** ตั้ง Off-site Backup, กำหนด RPO/RTO, ทำ Restore Test ใน Environment แยก, ตั้ง Central Logging/Alerting, ทำ Performance Baseline ที่ปลอดภัยและจัดทำ Cost Report จากข้อมูลจริง

**P5 — ปิดงานและยืนยัน:** รันทดสอบซ้ำเฉพาะ Endpoint ที่เกี่ยวข้อง ใช้คำขอจำกัด หลีกเลี่ยง Aggressive Fuzzing บน Production, กระทบยอด Finding IDs/Severity, แนบหลักฐาน Before/After และให้เจ้าของระบบอนุมัติสถานะปิดแต่ละข้อ

## เอกสารและหลักฐานอ้างอิง


1. alien_buu_1_8.md — รายงานบูรณาการฉบับล่าสุด จัดทำล่าสุดวันที่ 29 ตุลาคม 2569 เวลาประมาณ 22:20 น. ประเทศไทย
2. Host VPS evidence log: /home/T/audit_vps_20261029T1509Z.log — SHA-256: b41e6bc6d1e583ee95bc6931520a0f57259c1caa84d3b1326637ce2b0ebb2dfc
3. Client evidence log: /home/admin/audit_client_25691029T1509Z.log — SHA-256: 6547791f0d1ae50afb7be7921115b111a14fb334586c4c88bddd2c47262679f1
4. testssl.sh 3.3dev — รายงานผล TLS สิ้นสุดเวลา 29 ตุลาคม 2569 เวลา 22:13:57 น. ประเทศไทย; Grade A+, Score 96
5. Canonical, “Ubuntu release cycle,” https://ubuntu.com/about/release-cycle — ข้อมูลระยะเวลาสนับสนุน Ubuntu 24.04 LTS